

Zenaian Agentic AI Implementation Specification

Final minimal-change server / website / extension implementation plan

Final pre-implementation version 1.0 | August 14, 2026 | Repository snapshot d9137c605755

Final pre-implementation compliance specification. Operator/CPO placeholders remain for manual completion. Re-check Korean law in force on the actual launch date before publication.

0. Agent instruction and constraints

Work against repository jhbryan0817-del/snapgrok-api, snapshot d9137c6057556d1ab0a6fdb24e9024ae56b92ce. Re-resolve main immediately before modifying code; if main has moved, inspect the delta and preserve newer behavior. Do not silently overwrite newer billing/security logic.

- Primary goal: implement the locked privacy/compliance specification with minimal architectural disruption.
- Do not redesign Clerk authentication, Whop subscription lifecycle, quota semantics, extension pairing, or transient analysis flow except where explicitly required below.
- Never add screenshot/prompt/answer persistence, analytics, behavioral telemetry, raw provider payload storage, or a general-purpose user event warehouse.
- Use existing PostgreSQL stores, bounded cleanup jobs, server service pattern, Clerk authentication, Whop client and analysis-job manager.
- All privacy mutations must be idempotent/retryable. External provider failure must not resurrect or unblock a deletion-requested account.

1. Priority A - xAI ZDR fail-closed enforcement

1. Keep store:false in the xAI request body.
2. In requestXai(), after receiving the HTTP response and before accepting the body as a successful inference, read response.headers.get("x-zero-data-retention").
3. In production (NODE_ENV=production or a dedicated REQUIRE_XAI_ZDR=true defaulting true in production), require normalized header value === "true". If absent/false, cancel/discard the response and throw a safe structured error XAI_ZDR_REQUIRED / HTTP 502 or 503.
4. Do not include request body, screenshot, prompt, output, API key or header dump in the error/log.
5. Analysis-job failure must release the quota reservation through the existing release path.
6. Add unit tests: true accepted; false rejected; missing rejected in production; test/mock mode behavior explicit; retry must not bypass the header check.
7. Add a startup/deployment checklist note that the xAI Team Settings ZDR badge must be Active. Runtime checking is defense-in-depth against drift.

2. Priority B - remove Zenaian user-identifying Whop checkout metadata

Current issue

billing-service.js currently passes clerk_user_id, checkout_intent_id and a local plan nickname through Whop custom metadata, and webhook/reconciliation logic uses clerk_user_id metadata as a mapping signal. Whop exposes checkout_configuration_id specifically for mapping payments/memberships to the checkout that created them. The final privacy standard removes all unnecessary Zenaian user-identifying/linkable custom metadata from new checkout creation.

8. Change new checkout creation so no Zenaian user-identifying/linkable custom metadata is sent. Omit metadata entirely if the Whop API permits; otherwise send {}. Specifically remove clerk_user_id, checkout_intent_id and

sneaksolve_plan from new checkouts. Provider plan ID already defines the plan, and checkout_configuration_id provides the provider mapping key.

9. Continue creating billing_checkout_sessions locally before/around provider checkout creation. After Whop returns its ch_... checkout configuration ID, persist that ID in provider_checkout_id against the authenticated local Clerk user.
10. For first membership/payment mapping, use event/payment/membership.checkout_configuration_id to look up billing_checkout_sessions.provider_checkout_id in the correct provider_mode/company/product/plan. Require a unique matching local checkout.
11. For subsequent membership events, map by existing (provider_mode, provider_membership_id) first. For subsequent payment events, map via known provider membership or checkout configuration ID.
12. Remove safeClerkUserId(metadata.clerk_user_id) as a required mapping source for new objects. Preserve backward compatibility for already-mapped legacy memberships/payments if necessary, but do not require or newly create that metadata. Ignore unexpected user-identifying metadata rather than logging/trusting it.
13. If a provider event cannot be mapped safely, quarantine it and let reconciliation retrieve provider objects; do not loosen mapping validation or reintroduce broad PII metadata.
14. Update webhook/reconciliation tests for: normal no-metadata purchase; spoofed metadata ignored; wrong checkout ID rejected/quarantined; duplicate event idempotency; plan/product/company mismatch; payment and membership objects that carry checkout_configuration_id.
15. Confirm no public or internal log prints metadata.

Whop's current payment and membership API documentation explicitly exposes checkout_configuration_id and describes it as the ID used to map the object back to the checkout configuration that created it. Use that provider-native reference.

3. Priority C - forward migration for privacy/legal retention

Create migration 006_privacy_compliance.sql (or next sequential version). Do not edit already-applied migration files.

Create a dedicated PostgreSQL schema and tables:

```
CREATE SCHEMA IF NOT EXISTS legal_retention;
```

```
CREATE TABLE legal_retention.transaction_records (  
  record_id uuid PRIMARY KEY,  
  record_category text NOT NULL CHECK (record_category IN (  
    'contract_withdrawal','payment_supply','complaint_dispute'  
  )),  
  subject_lookup_hmac text NOT NULL,  
  former_account_hmac text NOT NULL,  
  hmac_key_version integer NOT NULL,  
  provider text NOT NULL DEFAULT 'whop',  
  provider_mode text,  
  provider_checkout_id text,  
  provider_membership_id text,  
  provider_payment_id text,  
  product_id text,  
  plan_id text,  
  plan_code text,  
  settlement_amount numeric,  
  currency text,  
  tax_amount numeric,  
  tax_behavior text,  
  billing_reason text,  
  status text,  
  contracted_at timestamptz,  
  paid_at timestamptz,  
  canceled_at timestamptz,  
  refunded_at timestamptz,  
  disputed_at timestamptz,
```

```

retention_basis text NOT NULL,
retention_expires_at timestampz NOT NULL,
created_at timestampz NOT NULL DEFAULT now(),
updated_at timestampz NOT NULL DEFAULT now()
);
-- Add narrow unique keys for provider transaction/category and indexes on
-- subject_lookup_hmac and retention_expires_at.

```

```

CREATE TABLE privacy_request_audit (
  request_id uuid PRIMARY KEY,
  subject_hmac text NOT NULL,
  request_type text NOT NULL,
  state text NOT NULL,
  received_at timestampz NOT NULL,
  completed_at timestampz,
  exception_code text,
  purge_after timestampz NOT NULL,
  created_at timestampz NOT NULL DEFAULT now(),
  updated_at timestampz NOT NULL DEFAULT now()
);

```

- Use a dedicated PRIVACY_ARCHIVE_HMAC_KEY environment secret (≥ 32 random bytes, base64url) and a key version. Never derive archive HMACs from the extension signing key, Clerk secret or database password.
- Normalize primary email with trim + lowercase only; do not invent aggressive canonicalization rules that can merge distinct addresses.
- HMAC both normalized primary email and Clerk user ID before Clerk deletion. Do not store raw email or live Clerk ID in legal_retention.
- Grant the application only the SQL privileges it needs. No normal account-status/query should join legal_retention.

4. Priority D - record statutory payment data without collecting extra PII

16. Extend Whop payment normalization to retain only fields needed for transaction evidence when present: provider payment ID, checkout_configuration_id, membership ID, plan/product/company, settlement_amount/final amount, currency, tax_amount, tax_behavior, billing_reason, paid/created/updated/refund/dispute status/timestamps.
17. Explicitly discard billing_address, card_last4, payment_method_type, customer profile, financing details and other provider fields not needed by Zenaian.
18. On confirmed payment success / relevant refund or dispute update, idempotently upsert legal_retention.transaction_records. Do this close to the existing webhook/reconciliation transaction so the statutory record is not dependent on later account deletion.
19. Calculate contract/payment retention expiry as the applicable event date + 5 years. Complaint/dispute record expiry = applicable complaint/dispute handling date + 3 years. If a record satisfies multiple categories, either store separate category records or set the maximum required expiry with explicit basis; separate rows are clearer.
20. Keep the live billing_payment_history compact for account UI; purge live payment history older than 12 months when a statutory archive copy exists.
21. Do not pull name/address/card data merely to make the archive “more complete.” The legal principle is minimum sufficient transaction evidence, not replication of the provider’s full payment object.

5. Priority E - privacy service/store

Add server/src/privacy-store.js and server/src/privacy-service.js following existing store/service patterns.

- privacy-store: create/update privacy request audit; compute/persist legal transaction snapshots; list current exportable rows; purge retention; delete operational rows by user in safe transaction order.

- privacy-service: authorize export/delete; obtain current Clerk profile through existing Clerk API client; orchestrate Whop cancellation; cancel analysis jobs; revoke device sessions; block user; archive; delete local data; delete Clerk user; return safe receipt.
- Introduce a small privacy_deletion_blocks table or equivalent persistent state if needed so a deletion request remains blocked across process restart/provider retry. Do not rely solely on RAM.
- Deletion state should be checked by analysis, pairing/session refresh, billing checkout/reactivation and entitlement access before allowing new activity.

6. Priority F - API routes

Add website-origin authenticated routes:

Route	Auth	Behavior
GET /api/privacy/export	Recent Clerk auth	Returns JSON export; content-disposition attachment optional. No secrets.
GET /api/privacy/summary	Recent Clerk auth	Human-page data model: categories, retention, provider transfer info, deletion availability.
POST /api/privacy/delete-account	Recent Clerk auth + exact website origin + confirmation payload	Begins idempotent deletion. Payload contains required booleans + confirmText="DELETE" only; no reason required.

- Do not add a public deletion endpoint keyed only by email.
- Consider Clerk reauthentication freshness / session age. For destructive deletion, reject if the session is too old and tell website to reauthenticate.
- Use generic errors to client; safe request ID for operator debugging.

7. Priority G - deletion orchestration order

22. Validate confirmation and recent auth.
23. Create/reuse deletion request; persist BLOCKED state before external/destructive work.
24. Cancel analysis jobs for user.
25. Revoke and delete device/pairing sessions.
26. Load Clerk primary email and active Whop mappings while the identities still exist.
27. Upsert any missing statutory transaction records using HMAC lookup keys.
28. Set Zenaian entitlement inaccessible immediately.
29. Request Whop cancel-at-period-end for each renewal-capable membership. If provider is down, store only minimum retry IDs and keep deletion BLOCKED/PARTIAL; schedule retry.
30. Delete live usage, checkout, membership, payment-history and linkable provider-event rows once no provider retry depends on them. Respect FK order.
31. Delete Clerk user last. A successful provider cancellation is preferred before Clerk deletion, but a temporary Whop outage must not restore user access. Keep an idempotent retry row.
32. Mark request COMPLETE; set purge_after = completed_at + 1 year. Return deletion receipt ID.
33. Never send a "come back" or marketing message after deletion.

8. Priority H - scheduled retention purges

Extend the existing 5-minute maintenance loop with bounded/indexed methods. It is acceptable to run daily-gated purge logic from the timer; do not scan full tables every five minutes.

Table/data	Rule
billing_analysis_usage	Delete settled rows older than 30 days.
billing_usage_periods	Delete periods 90 days after ends_at when no remaining analysis_usage FK row.

Table/data	Rule
billing_checkout_sessions	Delete failed/expired >7d; consumed >30d. Null checkout_url as soon as expired/consumed.
billing_provider_events	Keep existing 30d purge.
billing_memberships	Delete terminal operational row >90d after terminal state when statutory archive exists and no active reconciliation/cancellation retry.
billing_payment_history	Delete live rows >12mo when statutory archive exists; delete immediately on account deletion after archive.
legal_retention.transaction_records	Delete after retention_expires_at.
privacy_request_audit	Delete after purge_after, normally one year.

9. Priority I - legacy Lemon Squeezy removal

34. Add a forward migration; do not rewrite migration 001.
35. Before dropping, assert/log counts for billing_checkout_intents, billing_subscriptions and legacy billing_webhook_events. In production migration, fail safely if non-zero records exist unless an explicit reviewed migration/archive step handles them.
36. If confirmed obsolete/test-only, drop legacy Lemon tables and any code/env/tests that can write them.
37. Ensure no schema retains a raw webhook body jsonb column or generic raw provider-payload persistence path.
38. Update README/deployment guide to state Whop-only billing storage.

10. Priority J - website privacy UX

- Account > Privacy section: “View my data”, “Download JSON”, “Delete account”.
- Deletion modal with four explicit acknowledgement checkboxes plus typed DELETE. Explain immediate loss of remaining access/allowance, renewal-cancellation request, statutory archive exception, rolling backup aging and irreversibility.
- Do not ask the user why they are deleting.
- Add the final Privacy Policy and Terms routes using the approved text; operator placeholders remain until manually replaced.
- Update privacy contact to privacy@zenaia.com once Workspace exists.
- No analytics SDK or consent banner is required solely for analytics because none is used; do not add one just for appearance.
- Before allowing new account creation, show a clear 19+ / Terms representation (for example: “By creating an account, you confirm you are at least 19 and agree to the Terms and Privacy Policy.”). Do not collect date of birth. Use the lowest-code gate compatible with the existing Clerk flow; do not create a DOB database.

11. Priority K - Korea AI Basic Act transparency

- Advance notice: Website Terms, Chrome Web Store description, and a static line in the extension popup/settings must state that Zenaian uses generative AI (xAI Grok) to generate proposed answers from user-submitted screenshots. Do not add a server-side acknowledgement table solely for this notice.
- Use chrome.action.setTitle (or the equivalent existing action-title path) as the human-readable result marker while result states are displayed. Exact strings: single answer “AI-generated answer: B”; multiple answers “AI-generated answers: A, C”; inconclusive “AI-generated result: inconclusive”; processing “Zenaian - AI processing”. Restore the ordinary Zenaian title when the icon returns to idle.
- Preserve the discreet icon graphic and timing; the tooltip/title supplies the AI-generated marking without visually enlarging the result UI.
- Add tests for all exact title strings and verify the advance-notice text exists in the public Terms and extension UI/Chrome Web Store copy.

12. Priority L - sensitive-data warning

- In extension Settings/Privacy and public Terms/Privacy, state: "Do not submit screenshots containing identifiable sensitive personal information or credentials."
- Keep the warning concise and do not interrupt every capture. The static extension/privacy disclosure plus Terms is the default; no screenshot classifier or retention is added.
- Do not implement a content classifier that uploads/stores screenshots for "privacy scanning"; that would increase processing. Do not retain screenshots to enforce the prohibition.

13. Priority M - Whop legal configuration

- Upload Zenaian Terms of Service, Privacy Policy and Return Policy / Additional Terms in Whop Dashboard > Settings > Legal.
- Enable "Require terms and conditions acceptance."
- Ensure checkout/product text states recurring interval, base price, no trial if none, exclusive tax behavior, tax added where applicable, immediate digital access, cancellation path and statutory withdrawal language.
- Keep the seller's "Whop Collects and Remits" configuration where intended, but do not represent that Whop assumes all tax/consumer duties.
- Treat Whop as an independent platform/payment/data-sharing counterpart rather than a Zenaian-only processor. Current Seller Terms incorporate the Seller Data Sharing Addendum; the standalone text is not separately linked in the public legal page reviewed. Use Seller Terms + Whop Privacy Policy for implementation constraints, and review the standalone addendum later if Whop exposes it.

14. Priority N - Google Workspace configuration

- Create Workspace under Korean business registration; default recommended edition Business Standard.
- Set covered data-at-rest region = United States.
- Enable/enforce 2SV for super admin and privacy mailbox; prefer passkey/security key/Google Prompt.
- Create privacy@zenaian.com; no forwarding to personal Gmail.
- Configure Gmail Email and chat auto-deletion = 365 days, permanent deletion rather than Trash where operationally comfortable.
- Do not enable Vault by default.
- After setup, update the public transfer table from "planned" to actual and store an internal configuration evidence note.

15. Priority O - Hosting.kr privacy configuration

- Treat Hosting.kr / Megazone as the domestic Korean website-hosting contractor for the implementation. Do not add a Zenaian PIPA overseas-transfer row for it on current evidence.
- In cPanel Metrics Editor, disable/leave disabled Webalizer, AWStats and Analog Stats. Do not add another website analytics tool.
- Leave raw-access-log archiving disabled by default. If a security incident requires a downloaded log, retain the downloaded copy <=30 days unless a documented hold applies. If temporary archiving is enabled, enable deletion of the previous month archive at month-end and disable archiving after the incident.
- Do not place Zenaian application/account databases or screenshot/AI data on Hosting.kr.
- If the hosting service is intentionally terminated, use explicit customer cancellation rather than passive expiry so current Hosting.kr guidance applies immediate deletion/no long-backup recovery.
- Optional later check: inspect the actual cPanel/server IP or provider evidence. If it establishes an overseas region, update the Privacy Policy/Article 28-8 register in the next compliance revision.

16. Tests required before merge

- xAI ZDR header true/false/missing production behavior; no quota charge on ZDR failure.

- No screenshot/instruction/answer appears in DB or logs after success/failure/cancel/timeout.
- Whop checkout creates/matches with no Zenaian user-identifying custom metadata; checkout_configuration_id/provider-ID mapping works for success/renewal/failure/refund/dispute and legacy mapped objects remain compatible.
- Legal archive stores only approved fields and HMAC identifiers; no raw email/Clerk ID/card/billing address.
- Deletion happy path; second deletion/idempotent retry; Whop outage; Clerk outage; restart during deletion; late Whop webhook after deletion; backup deletion ledger replay.
- Retention purge boundaries at 30d/90d/12mo/3y/5y with FK-safe batching.
- Export contains current data + legal archive but no secrets/content history.
- AI-generated Chrome action hover titles match the exact approved strings; generative-AI advance notice exists in Terms and extension/Chrome Web Store UI.
- Legacy Lemon migration refuses unsafe drop if unexpected production records exist.

17. Acceptance criteria

- Production capture cannot proceed unless xAI ZDR is confirmed by response header.
- No Zenaian user-identifying/linkable custom metadata is sent on new Whop checkout creation.
- Account deletion immediately blocks service and normally completes active-system deletion within 24h; only segregated statutory/minimum retry/audit data remains.
- PIPA operational retention windows are implemented automatically, not merely described in policy.
- Korean E-Commerce statutory records survive for the correct legal period and are separated from live account data.
- Chrome extension and website satisfy generative-AI advance notice/result marking without materially compromising the discreet answer-icon design.
- No third-party analytics/behavioral tracking is added.
- Website Privacy Policy, Website Terms, Whop terms/return policy and actual code behavior match.

Source register

[L1] **Korea Personal Information Protection Act (PIPA), current text.** <https://law.go.kr/LSW/lsInfoP.do?lsiSeq=270351>

[L2] **PIPA Article 28-8 - overseas transfers.** <https://www.law.go.kr/LSW/lsLinkCommonInfo.do?chrClsCd=010202&lsJoLnkSeq=1029334737>

[L3] **PIPC Privacy Policy Writing Guidelines, April 2026.** <https://www.pipc.go.kr/np/cop/bbs/selectBoardArticle.do?bbsId=BS217&mCode=D010030000.Updated&nttlId=12018>

[L4] **Korean E-Commerce Act Articles 17-18 - withdrawal and refunds.** <https://law.go.kr/LSW/lsLinkCommonInfo.do?chrClsCd=010202&lsJoLnkSeq=1013449821>

[L5] **Korean E-Commerce Act Enforcement Decree Article 6 - transaction-record retention.** <https://www.law.go.kr/LSW/lsInfoP.do?lsiSeq=288143>

[L6] **Korean Civil Act Articles 4-5 - majority and minors.** <https://www.law.go.kr/LSW/lsInfoP.do?lsiSeq=284415>

[L7] **Korea AI Basic Act Article 31 - generative-AI transparency.** <https://www.law.go.kr/LSW/lsLinkCommonInfo.do?lsJoLnkSeq=1031809549>

[L8] **Korea AI Basic Act Enforcement Decree Article 23 - disclosure/marketing methods.** <https://www.law.go.kr/lsLinkCommonInfo.do?lspttninfSeq=198075>

[L9] **PIPA Enforcement Decree Articles 39-40 - 72-hour breach notice/reporting.** <https://www.law.go.kr/LSW/lsLawLinkInfo.do?chrClsCd=010202&lsJoLnkSeq=1000089686>

[V1] **xAI API Security FAQ - Zero Data Retention.** <https://docs.x.ai/developers/faq/security>

[V2] **xAI Enterprise Terms.** <https://x.ai/legal/terms-of-service-enterprise>

[V3] **xAI DPA.** <https://x.ai/legal/data-processing-addendum>

[V4] **xAI Subprocessor List.** <https://x.ai/legal/subprocessor-list>

[V5] **Render Regions.** <https://render.com/docs/regions>

[V6] **Render Logs.** <https://render.com/docs/logging>

[V7] **Render Postgres Recovery and Backups.** <https://render.com/docs/postgresql-backups>

[V8] Clerk DPA. <https://clerk.com/legal/dpa>

[V9] Clerk deleteUser API. <https://clerk.com/docs/reference/backend/user/delete-user>

[V10] Whop Seller Terms - incorporates Seller Data Sharing Addendum. <https://whop.com/seller-terms/>

[V11] Whop legal-document upload and acceptance controls.
<https://docs.whop.com/manage-your-business/manage-business/legal-documents>

[V12] Whop Payment API. <https://docs.whop.com/api-reference/payments/retrieve-payment>

[V13] Whop Membership API. <https://docs.whop.com/api-reference/memberships/retrieve-membership>

[V14] Whop Privacy Policy. <https://whop.com/privacy/>

[V15] Google Workspace Data Regions. <https://support.google.com/a/answer/14310028>

[V16] Google Workspace Gmail Auto-Delete. <https://support.google.com/a/answer/151128>

[V17] Google Workspace 2-Step Verification. <https://support.google.com/a/answer/175197>

[V18] Google Workspace Subprocessors. <https://workspace.google.com/terms/subprocessors/>

[V19] Hosting.kr / Megazone Privacy Policy. <https://www.hosting.kr/policies/privacy>

[V20] Hosting.kr Linux webhosting - AWS-based hosting environment. <https://www.hosting.kr/webhosting>

[V21] Hosting.kr Raw Access log controls. <https://help.hosting.kr/hc/ko/articles/900005240146>

[V22] Hosting.kr Metrics Editor - Webalizer / Analog / AWStats controls.
<https://help.hosting.kr/hc/ko/articles/900006193483>

[V23] Hosting.kr cancellation / deletion and long-backup behavior.
<https://help.hosting.kr/hc/ko/articles/4408216133529>

[V24] Whop Seller Data Sharing Addendum - incorporated by reference in Seller Terms; public Seller Terms provide the controlling incorporation point. <https://whop.com/seller-terms/>